



Build Your Zombie Survival Kit: Threat- Informed Defence for Real-World Attacks

Kade Morton. Co-Founder. Arachne Digital.

A bit about me

I'm Kade! A survivor of the zombie apocalypse.

I've been working in security for eight years.

I cofounded Arachne Digital, a cyber threat intelligence firm focused on threat-informed defence.

We are forming the Threat-Informed Defence Alliance

<https://www.arachne.digital/>

<https://www.threatinformeddefence.com>



How did the zombie
apocalypse happen?



Everyone
knew zombies
were slow



Best practice from the 60's

George Romero's *Night of the Living Dead* (1968) popularised slow zombies.

Cybersecurity best practice was written down at this point and everyone treated it as the gospel truth.



But actually,
they were
fast



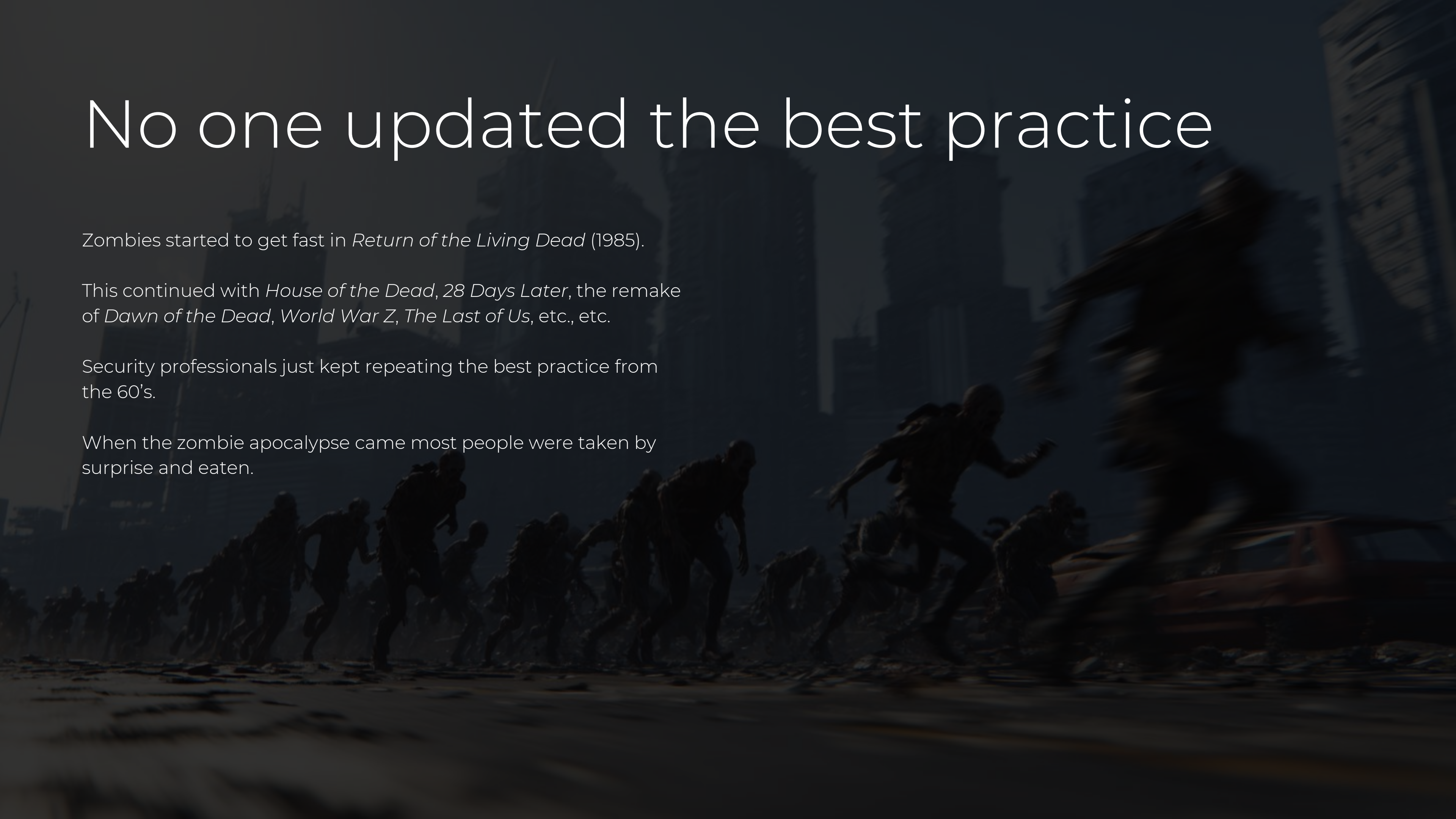
No one updated the best practice

Zombies started to get fast in *Return of the Living Dead* (1985).

This continued with *House of the Dead*, *28 Days Later*, the remake of *Dawn of the Dead*, *World War Z*, *The Last of Us*, etc., etc.

Security professionals just kept repeating the best practice from the 60's.

When the zombie apocalypse came most people were taken by surprise and eaten.



What is the
fastest
growing
form of
credential
theft?



T1555.003 Credentials from Password Stores: Credentials from Web Browsers

Most stealers have modules for stealing credentials from the major browsers

Most devices have browsers

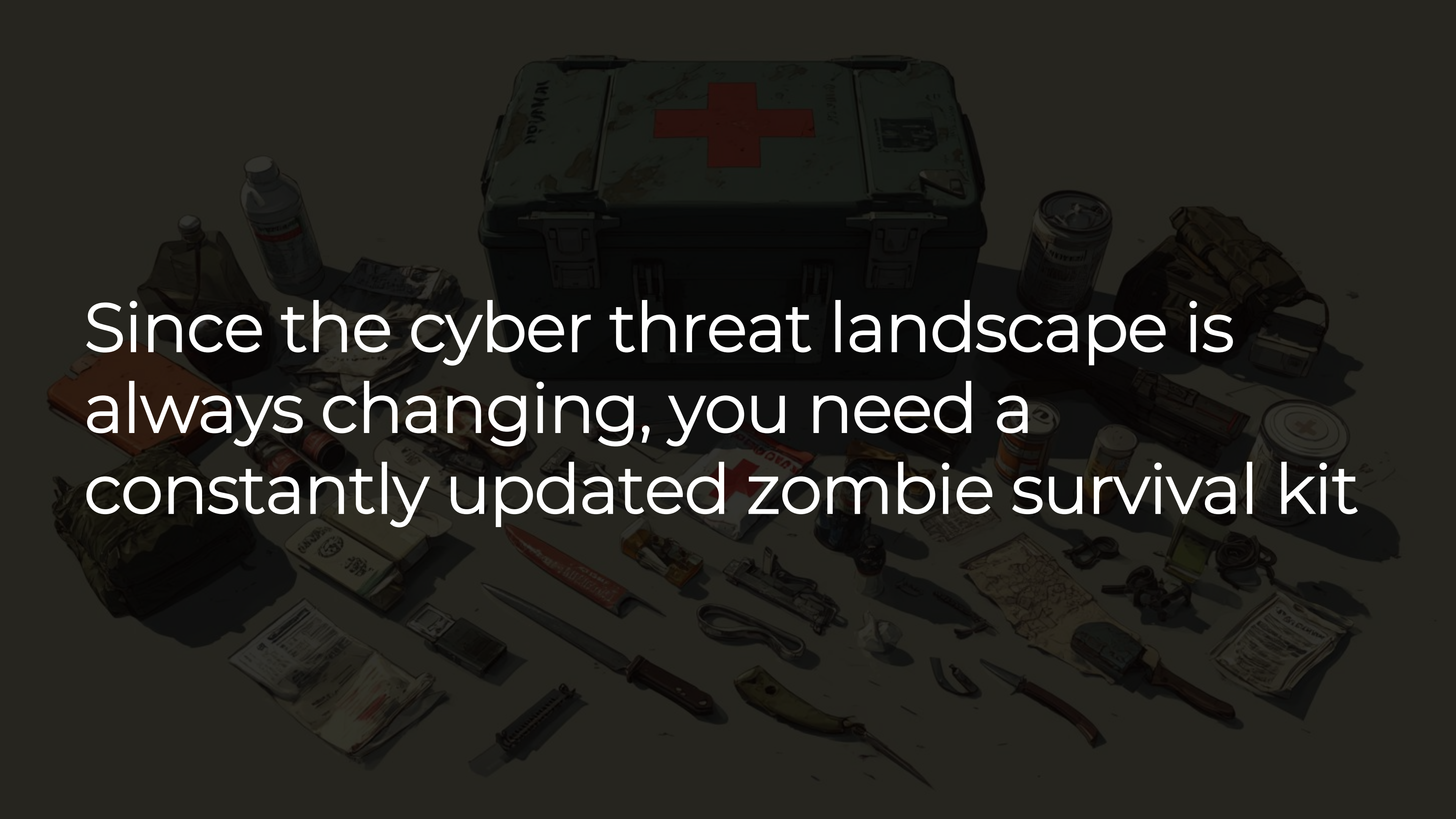
Most people save credentials in browsers for convenience

Just dropping Mimikatz in an environment with any sort of detections will get found fast

No one is looking for credentials being stolen from browsers

Cyber threat actors will go where credentials are plentiful, easy to access and attacks aren't being monitored

The cyber threat landscape is always changing, just like zombies

The background image is a dark, high-contrast illustration of various survival supplies. At the top center is a large, dark green first aid kit with a prominent red cross. Surrounding it are numerous items: a water bottle, a can of food, a map, a knife, a flashlight, a compass, a radio, a bag of food, a box of band-aids, a box of matches, a box of batteries, a box of tools, a box of first aid supplies, a box of food, a box of clothing, a box of shelter, a box of communication, a box of navigation, a box of defense, a box of offense, a box of survival, a box of life, a box of death, a box of everything. The items are scattered across a dark surface, creating a sense of a well-prepared survival kit.

Since the cyber threat landscape is
always changing, you need a
constantly updated zombie survival kit

Don't assume you know. Go look

Threat-informed defence (TID)

This is the methodology for building your zombie survival kit.

Threat-informed defence is the systematic application of an understanding of adversary tactics, techniques, and procedures (TTPs) to strengthen cybersecurity measures.

It involves using real-world threat intelligence to guide decisions about detection, prevention, and response.

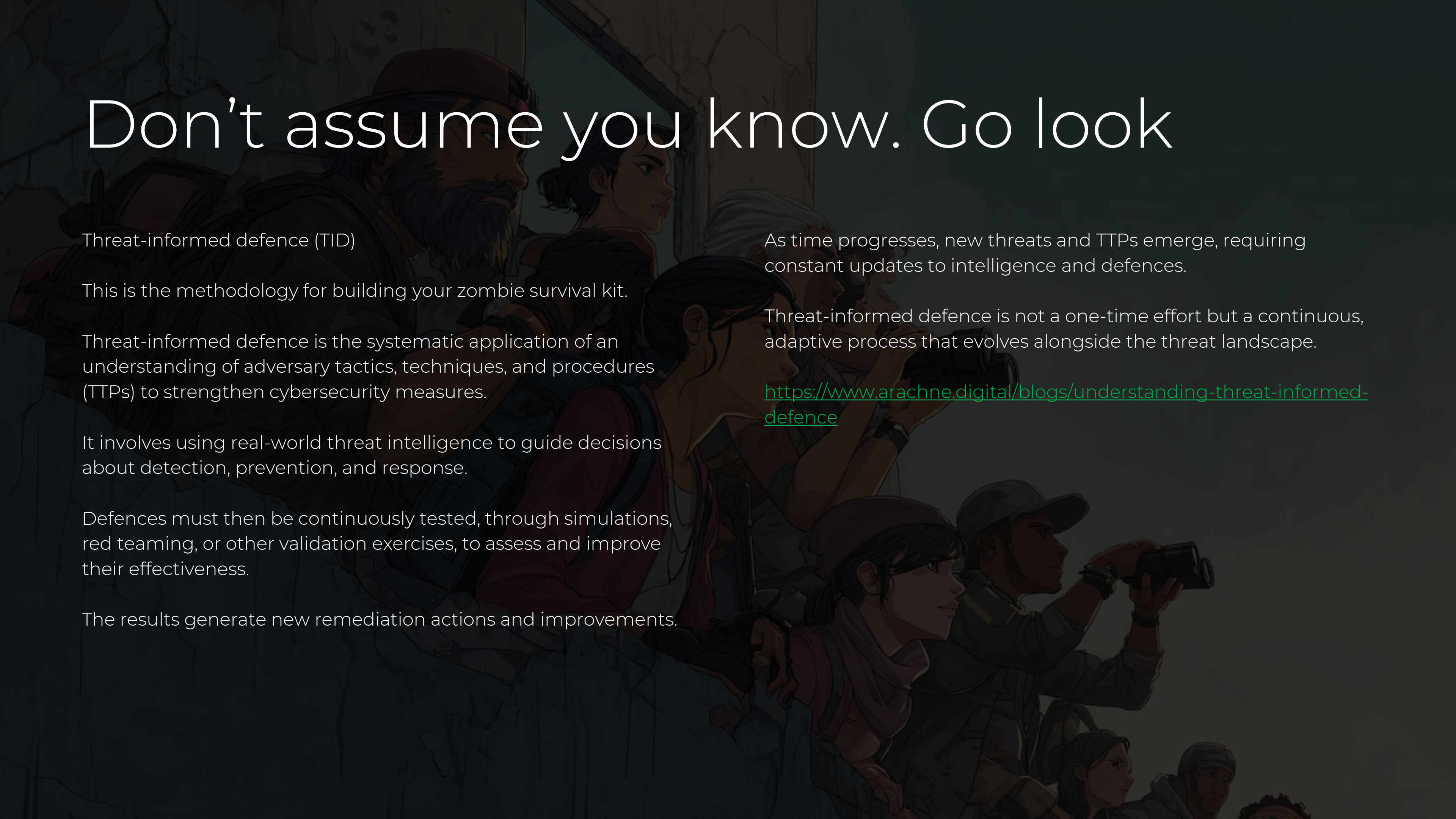
Defences must then be continuously tested, through simulations, red teaming, or other validation exercises, to assess and improve their effectiveness.

The results generate new remediation actions and improvements.

As time progresses, new threats and TTPs emerge, requiring constant updates to intelligence and defences.

Threat-informed defence is not a one-time effort but a continuous, adaptive process that evolves alongside the threat landscape.

<https://www.arachne.digital/blogs/understanding-threat-informed-defence>



First, you need threat intelligence

Intelligence is just knowledge about the real world that helps a decision maker make a better decision.

You want to know who targets your industry and geography, for example banking in Oceania.

In intelligence there is a saying, to predict the future you look to the past.

Your adversaries have reasons for targeting your industry and geography. This could be where they speak the language, you might have sensitive data, etc.

Those things will likely not change tomorrow.

Can be as simple as a reminder to search for news of recent attacks every six months.

Can be as complex as having a vendor that generates bespoke reports for you.

Intelligence should have three levels

Strategic – guiding long term business and security planning

Operational – guiding the management of security operations

Tactical – guiding analysts in day-to-day work

Examples:

Strategic – We are seeing long term trends of set TTPs. We should ensure we have people with set skills, processes in place and the right tooling to mitigate and detect this class of TTP.

Operational – We are seeing our industry and geography targeted by set cyber threat actors. We should ensure the SIEM has coverage for all their common TTPs.

Tactical – We are seeing set TTPs used in a chain. We should ensure that our threat hunting covers this type of activity.

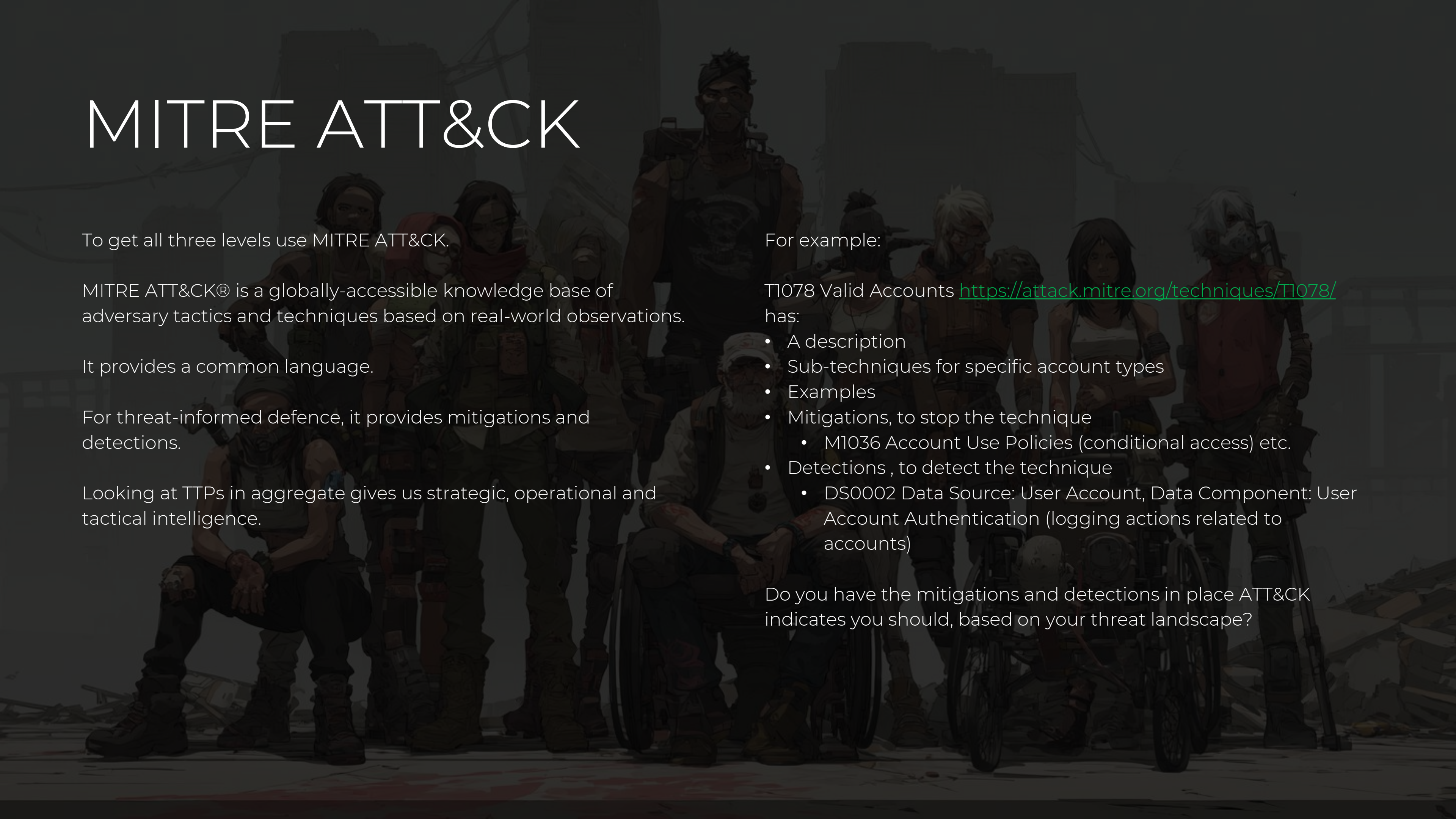
IoCs (indicators of compromise) alone are not intelligence.

You cannot plan strategy around IoCs.

You cannot plan security operations around IoCs.

You cannot (or should not) plan day to day work solely around IoCs.

MITRE ATT&CK

A group of diverse, stylized characters in tactical gear standing in a dark, industrial setting. The characters are of various ethnicities and ages, some wearing helmets and carrying equipment. They are positioned in a group, with some standing and some crouching or kneeling. The background is dark and industrial, with some structures visible.

To get all three levels use MITRE ATT&CK.

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations.

It provides a common language.

For threat-informed defence, it provides mitigations and detections.

Looking at TTPs in aggregate gives us strategic, operational and tactical intelligence.

For example:

T1078 Valid Accounts <https://attack.mitre.org/techniques/T1078/> has:

- A description
- Sub-techniques for specific account types
- Examples
- Mitigations, to stop the technique
 - M1036 Account Use Policies (conditional access) etc.
- Detections , to detect the technique
 - DS0002 Data Source: User Account, Data Component: User Account Authentication (logging actions related to accounts)

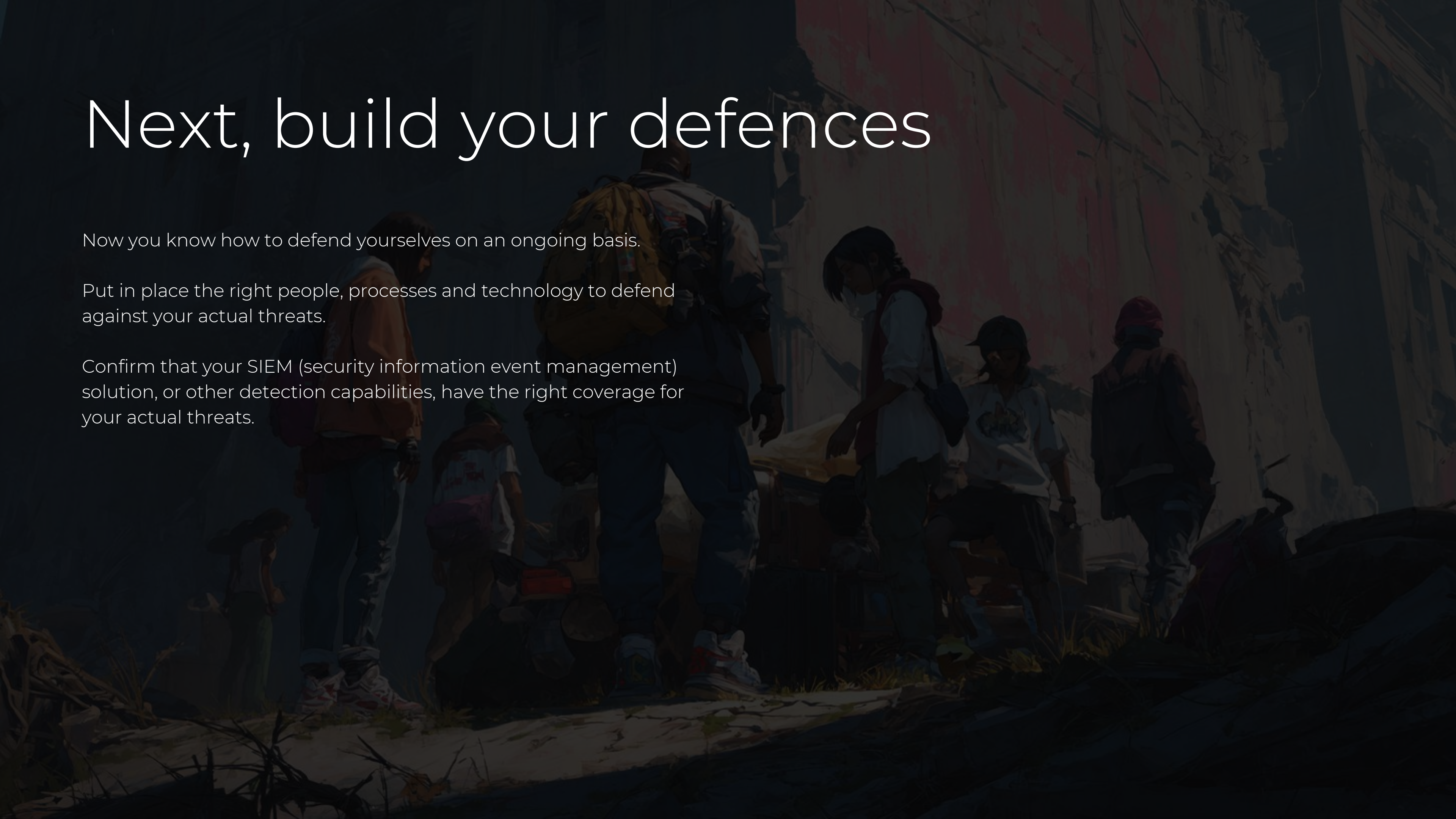
Do you have the mitigations and detections in place ATT&CK indicates you should, based on your threat landscape?

Next, build your defences

Now you know how to defend yourselves on an ongoing basis.

Put in place the right people, processes and technology to defend against your actual threats.

Confirm that your SIEM (security information event management) solution, or other detection capabilities, have the right coverage for your actual threats.



Then, test your defences

Test that you can detect, mitigate and respond to the TTPs you know actually matter.

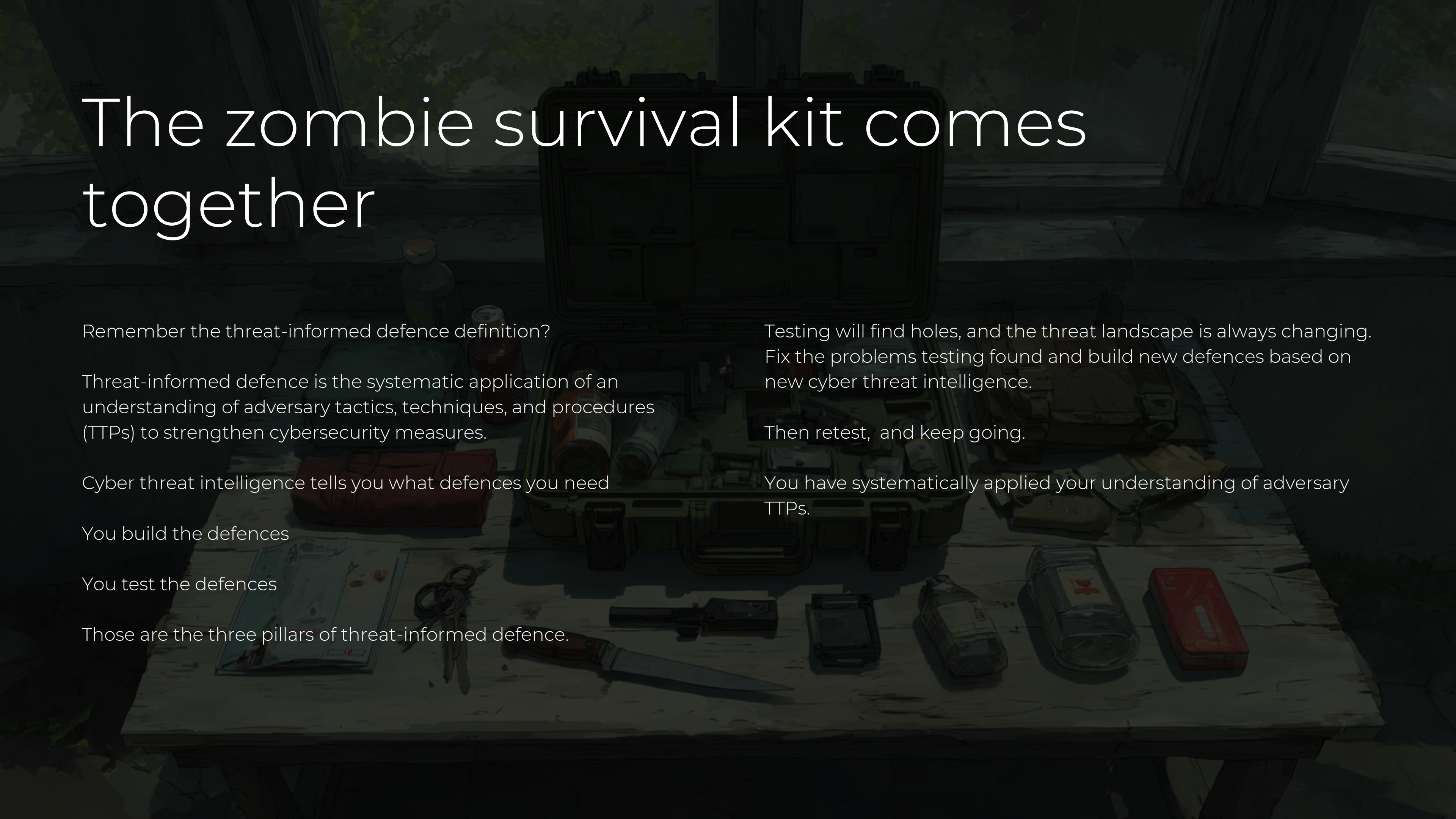
Can be a red team, adversary emulation, or a purple team exercise.

Use tools like MITRE Caldera <https://caldera.mitre.org/>

Don't get someone in to do a generic testing, they might still think zombies are slow.

Ensure the party performing the testing is using up to date cyber threat intelligence and that they are testing the specific TTPs you're defending against.

The zombie survival kit comes together

A detailed illustration of a zombie survival kit laid out on a wooden table. The kit includes a large open plastic case with various compartments, a handgun, a combat knife, a first aid kit, a flashlight, a radio, a map, a compass, a water bottle, a canteen, a bandana, and several other survival tools and supplies. The background shows a window with a view of a dark, forested area, suggesting a post-apocalyptic setting.

Remember the threat-informed defence definition?

Threat-informed defence is the systematic application of an understanding of adversary tactics, techniques, and procedures (TTPs) to strengthen cybersecurity measures.

Cyber threat intelligence tells you what defences you need

You build the defences

You test the defences

Those are the three pillars of threat-informed defence.

Testing will find holes, and the threat landscape is always changing. Fix the problems testing found and build new defences based on new cyber threat intelligence.

Then retest, and keep going.

You have systematically applied your understanding of adversary TTPs.

The next step - Flows

In July 2025 MITRE released Flows

Read more about it here: <https://www.arachne.digital/blogs/from-reports-to-routes-visualising-adversary-paths-with-thread-and-mitre-attack-flow-builder>

Rather than just look at TTPs, Flows show how a series of TTPs are strung together by a cyber threat actor to achieve objectives.

For example, T1190 Exploit Public-Facing Application into T1018 Remote System Discovery into T1021.004 Remote Services: SSH etc etc.

See what real attacks look like in your environment then work through how to defend yourself!

Timely & Actionable

Cyber Threat
Intelligence



ARACHNE

Kade Morton
LinkedIn Profile



Arachne Digital
LinkedIn Page